

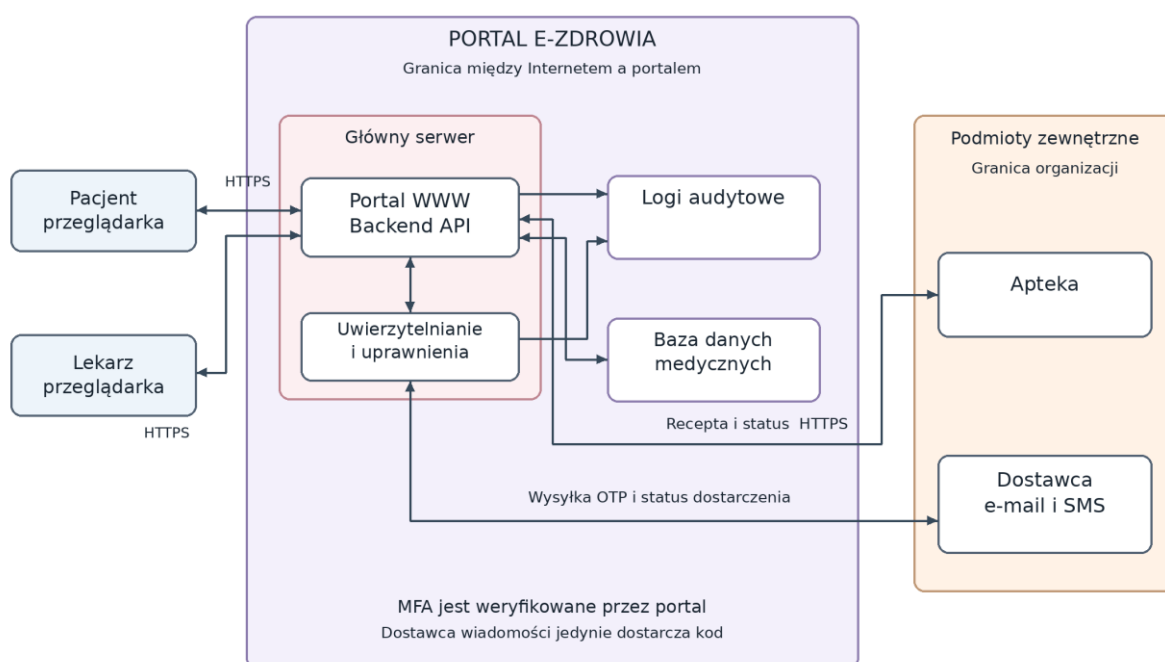
Lekcja 14_Modele zagrożeń i zarządzanie ryzykiem – homework

Model zagrożeń portalu e-zdrowia

1. Wybrany scenariusz

Portal z dokumentami medycznymi. Pacjent przegląda własną dokumentację. Lekarz odczytuje i aktualizuje dokumentację pacjentów, do których ma uprawnienia. Apteka otrzymuje dane potrzebne do realizacji recept, a dostawca email/SMS obsługuje dostarczanie kodów powiadomień.

2. Diagram przepływu danych DFD (Data Flow Diagram)



3. Granice zaufania

Internet i urządzenia użytkowników, a portal

Na diagramie pacjent i lekarz znajdują się poza obszarem portalu. Granicę przekraczają logowanie, kod MFA, identyfikatory dokumentów, żądania API oraz odpowiedzi zawierające dane medyczne. Żądania zalogowanego użytkownika wymagają kontroli.

Kontrola: HTTPS, walidacja danych, ograniczenie liczby żądań, bezpieczne sesje oraz autoryzacja każdej operacji po stronie backendu.

Backend, a moduł uwierzytelniania i uprawnień

Moduł sprawdza sesję i rolę, a backend stosuje tę decyzję przy dostępie do konkretnego dokumentu.

Kontrola: weryfikacja sesji lub tokena, uprawnienia pobierane z zaufanego źródła, odmowa dostępu przy braku jednoznacznego uprawnienia.

Główny serwer, a baza danych i logi audytowe

Baza i logi są odrębnymi magazynami danych. Dostęp do nich odbywa się przez konta o określonych prawach. Pacjent, lekarz i apteka nie łączą się bezpośrednio z bazą. Logi przyjmują zdarzenia z backendu i modułu uprawnień, aby rejestrować także nieudane próby dostępu.

Kontrole: brak publicznego dostępu do bazy, minimalne prawa kont usługowych, ochrona połączeń oraz oddzielne uprawnienia do odczytu i zapisu logów.

Portal, a podmioty zewnętrzne

Apteka i dostawca e-mail/SMS należą do innych obszarów. Do apteki trafiają wyłącznie dane recepty niezbędne do realizacji; jej odpowiedź nie może samodzielnie zmieniać zaleceń lekarza. Dostawca wiadomości otrzymuje dane kontaktowe i treść kodu lub powiadomienia.

Kontrole: HTTPS, uwierzytelnianie usług, ograniczenie zakresu ich uprawnień. Kod OTP (One Time Password) ma krótki czas ważności, jest jednorazowy i powiązany z konkretną próbą logowania.

4. Analiza STRIDE

(S) Spoofing czyli podszywanie się

Atakujący przejmując konto lekarza lub jego aktywną sesję i wykonuje operacje jako lekarz. Może to nastąpić przez phishing, kradzież sesji albo obejście procedury odzyskiwania dostępu mimo MFA.

Elementy: Lekarz, portal, moduł uwierzytelniania, integracja e-mail/SMS.

Skutek: Nieuprawniony dostęp do dokumentacji oraz działania przypisane lekarzowi.

(T) Tampering, czyli nieuprawniona modyfikacja

Atakujący wykorzystuje błąd lub nadmierne prawa konta usługowego, aby zmienić dawkowanie leku w dokumentacji lub receptce. Podmienione dane mogą następnie trafić do pacjenta i apteki.

Elementy: Backend, baza danych, przepływ portal–apteka.

Skutek: Utrata integralności dokumentacji i możliwe zagrożenie zdrowia pacjenta.

(R) Repudiation, czyli wyparcie się działania

Pracownik lub lekarz podmienia dokument, a następnie zaprzecza wykonaniu tej operacji. Brak pełnych i chronionych logów nie pozwala wiarygodnie powiązać zmiany z kontem, czasem i wersją dokumentu.

Elementy: Lekarz, backend, baza danych, logi audytowe.

Skutek: Utrudnione wyjaśnienie incydentu i ustalenie odpowiedzialności.

(I) Information Disclosure, czyli ujawnienie informacji

Pacjent odczytuje dokumentację innej osoby, ponieważ backend nie sprawdza jego prawa do tego rekordu.

Elementy: Pacjent, API, moduł uprawnień, baza, logi.

Skutek: Naruszenie poufności danych medycznych.

(D) Denial of Service, czyli odmowa usługi

Atakujący przeciąża portal licznymi żądaniami logowania lub pobierania dokumentów, wyczerpuje zasoby, bazy lub limity wysyłki kodów MFA.

Elementy: Portal, moduł uwierzytelniania, baza, logi, dostawca email/SMS; przeciążenie może też zablokować integrację z apteką.

Skutek: Pacjenci i lekarze nie mogą korzystać z dokumentacji lub zalogować się.

(E) Elevation of Privilege czyli podniesienie uprawnień

Pacjent lub konto integracji wykorzystuje błąd autoryzacji, aby wykonać funkcję lekarza albo administratora, np. zmienić rolę lub edytować cudzą dokumentację.

Elementy: Pacjent, partnerzy, backend, logi.

Skutek: Przekroczenie dozwolonych uprawnień.

5. Ocena prawdopodobieństwa i wpływu

ID	Scenariusz	Prawdopodo- bieństwo	Wpływ	Ryzyko
S	Przejęcie konta lekarza	niskie	wysoki	średnie
T	Nieuprawniona zmiana dawkowania	średnie	wysoki	wysokie
R	Wyparcie się zmiany dokumentu	średnie	średni	średnie
I	Odczyt cudzej dokumentacji	średnie	wysoki	wysokie
D	Przeciążenie portalu lub logowania	średnie	średni	średnie
E	Uzyskanie funkcji lekarza lub administratora	średnie	wysoki	wysokie

Macierz ryzyka:

Prawdopodobieństwo	Wpływ niski	Wpływ średni	Wpływ wysoki
wysokie	średnie	wysokie	wysokie
średnie	niskie	średnie	wysokie
niskie	niskie	niskie	średnie

6. TOP 3 ryzyka i mitygacja

W przyjętej macierzy (T), (I) i (E) mają wysokie ryzyka.

1. Nieuprawniona zmiana dawkowania leku (T)

Prawdopodobieństwo: średnie. Wpływ: wysoki. Ryzyko: wysokie.

Uzasadnienie: zmodyfikowane dane mogą wyglądać jak prawidłowe zalecenie lekarza i zostać odczytane przez pacjenta lub przekazane do apteki.

- Sprawdzać po stronie backendu prawo lekarza do edycji konkretnej dokumentacji; pacjent i apteka nie mogą edytować dawkowania.

- Wymagać dodatkowego potwierdzenia tożsamości przy zmianach szczególnie wrażliwych i nadawać kontom usługowym minimalne prawa do zapisu.
- Przechowywać wersje dokumentów oraz chroniony audyt: konto, czas, identyfikator dokumentu, poprzednia i nowa wartość oraz alarmować o nietypowych zmianach.

Sprawdzenie: próba zapisu z konta pacjenta lub apteki jest odrzucana; prawidłowa zmiana lekarza tworzy nową wersję i wpis audytowy.

2. Ujawnienie dokumentacji innego pacjenta (I)

Prawdopodobieństwo: średnie. Wpływ: wysoki. Ryzyko: wysokie.

Uzasadnienie: błąd dostępu do rekordu może pozwolić na odczyt wielu dokumentów.

- Sprawdzać uprawnienia do każdego dokumentu przy każdym odczycie i pobraniu; weryfikować właściciela dokumentu lub uprawnioną relację lekarz–pacjent.
- Stosować role wraz z kontrolą dostępu do konkretnego rekordu. Domyślnie odmawiać dostępu.
- Ograniczyć dane przekazywane aptece i dostawcy wiadomości.

Sprawdzenie: pacjent A nie odczyta dokumentu pacjenta B po ręcznej zmianie zapytania; odpowiedź od serwera nie ujawnia treści dokumentu.

3. Uzyskanie funkcji lekarza lub administratora (E)

Prawdopodobieństwo: średnie. Wpływ: wysoki. Ryzyko: wysokie.

Uzasadnienie: podwyższone uprawnienia mogą umożliwić zarówno odczyt cudzych danych, jak i zmianę dokumentacji.

- Kontrolować rolę i dozwoloną operację po stronie serwera. Nie przyjmować roli administratora z niezweryfikowanego tokena.
- Oddzielić konta administracyjne od kont pacjentów i lekarzy; ograniczyć uprawnienia kont usługodawców oraz okresowo je przeglądać.
- Testować funkcje lekarza i administratora z konta pacjenta oraz partnera/usługodawcy. Rejestrować i alarmować zmiany ról oraz próby przekroczenia uprawnień.

Sprawdzenie: bezpośrednie wywołanie funkcji administracyjnej przez pacjenta lub partnera jest odrzucane.